# LAPORAN UJIAN TENGAH SEMESTER

# IT GOVERNANCE AND AUDIT

# MAGISTER TEKNIK INFORMATIKA



**Disusun Oleh:**



| | |
|---|---|
| **Nama** | **Muhammad Abiyyu Rahman 25.51.1738** |
| **Dosen Pengampu** | **Dr. Emigawaty, M.Kom.** |





**MAGISTER TEKNIK INFORMATIKA**

**FAKULTAS ILMU KOMPUTER**

**UNIVERSITAS AMIKOM YOGYAKARTA**

**2026**

## RINGKASAN EKSEKUTIF

Audit tata kelola teknologi informasi ini dilaksanakan terhadap PT Nusantara Retail, sebuah perusahaan retail menengah yang beroperasi melalui 15 toko fisik yang tersebar di wilayah Pulau Jawa serta mengelola platform e-commerce nusantaramart.id yang diluncurkan pada tahun 2022 sebagai bagian dari strategi transformasi digital perusahaan. Dengan pertumbuhan transaksi digital yang signifikan dalam dua tahun terakhir, ketergantungan operasional bisnis terhadap infrastruktur dan sistem teknologi informasi semakin meningkat, sehingga kebutuhan terhadap tata kelola TI yang terstruktur dan efektif menjadi semakin mendesak.

Audit ini dilaksanakan menggunakan framework COBIT 2019 (Control Objectives for Information and Related Technologies) sebagai acuan utama dalam mengevaluasi efektivitas tata kelola dan manajemen layanan TI. COBIT 2019 dipilih karena menyediakan governance and management objectives yang komprehensif, dapat disesuaikan dengan konteks organisasi, serta diakui secara internasional sebagai standar best practice tata kelola TI. Pelaksanaan audit mencakup evaluasi terhadap delapan domain COBIT 2019 yang relevan dengan karakteristik operasional perusahaan retail dan e-commerce, meliputi aspek risk governance, risk management, information security, change management, incident management, business continuity, security services, dan performance monitoring.

Selama proses audit, auditor melakukan review terhadap dokumentasi internal yang tersedia, observasi terhadap prosedur operasional divisi TI, serta wawancara dengan staf IT dan manajemen operasional perusahaan. Berdasarkan hasil evaluasi, ditemukan sejumlah temuan signifikan yang memerlukan perhatian segera, antara lain ketiadaan prosedur change management yang menyebabkan downtime selama 3 jam 20 menit pada saat flash sale 12.12 dengan estimasi kerugian transaksi senilai Rp 420 juta, belum tersedianya Business Continuity Plan dan Disaster Recovery Plan yang terdokumentasi, lemahnya pengelolaan keamanan informasi termasuk tidak adanya kebijakan keamanan formal dan enkripsi data pelanggan yang belum menyeluruh, serta tidak adanya sistem monitoring performa layanan TI yang terintegrasi.

## LATAR BELAKANG

PT Nusantara Retail merupakan perusahaan retail menengah yang bergerak di bidang penjualan produk kebutuhan sehari-hari, elektronik, dan fashion. Perusahaan mengoperasikan 15 toko fisik yang tersebar di wilayah Jawa Barat, DKI Jakarta, Jawa Tengah, dan Jawa Timur, serta mengelola platform e-commerce

nusantaramart.id yang diluncurkan pada tahun 2022 sebagai bagian dari strategi ekspansi digital perusahaan. Saat ini, PT Nusantara Retail memiliki kurang lebih 500 karyawan yang tersebar di seluruh unit operasional, dengan divisi teknologi informasi yang terdiri dari 8 staf IT yang menangani seluruh kebutuhan sistem informasi, infrastruktur jaringan, dan dukungan teknis operasional perusahaan.

Dalam beberapa tahun terakhir, perusahaan mengalami pertumbuhan transaksi digital yang cukup signifikan seiring dengan meningkatnya adopsi belanja online di kalangan konsumen Indonesia. Platform e-commerce nusantaramart.id mencatat pertumbuhan jumlah pengguna aktif hingga 300% dalam kurun waktu dua tahun sejak diluncurkan, dengan volume transaksi harian yang terus meningkat terutama pada periode promosi besar seperti flash sale bulanan dan event harbolnas. Kondisi ini menyebabkan ketergantungan operasional bisnis terhadap ketersediaan dan keandalan sistem teknologi informasi semakin kritis, sehingga gangguan pada sistem TI dapat berdampak langsung terhadap pendapatan, reputasi, dan kepercayaan pelanggan.

Seiring dengan meningkatnya kompleksitas dan ketergantungan operasional terhadap sistem TI, PT Nusantara Retail menghadapi berbagai tantangan dalam pengelolaan layanan teknologi informasi. Pada pelaksanaan flash sale 12.12 tahun 2024, platform e-commerce mengalami downtime selama 3 jam 20 menit yang disebabkan oleh proses pembaruan sistem yang dilakukan langsung pada environment produksi tanpa melalui prosedur change management yang semestinya. Insiden tersebut mengakibatkan estimasi kerugian transaksi senilai Rp 420 juta dan memicu lebih dari 200 komplain pelanggan melalui berbagai kanal komunikasi. Selain itu, pengelolaan data pribadi pelanggan yang tersimpan dalam database sistem belum sepenuhnya dilindungi oleh kebijakan keamanan informasi yang terstandarisasi, yang berpotensi menimbulkan risiko kepatuhan terhadap regulasi perlindungan data yang semakin ketat di Indonesia.

Permasalahan lain yang teridentifikasi meliputi belum tersedianya mekanisme backup data yang terjadwal dan terverifikasi, tidak adanya Business Continuity Plan maupun Disaster Recovery Plan yang terdokumentasi, serta ketiadaan platform ticketing untuk penanganan insiden layanan TI secara formal. Pengelolaan akses sistem juga ditemukan belum menerapkan prinsip least privilege,

dengan beberapa akun karyawan yang telah resign masih aktif dalam sistem. Kondisi-kondisi tersebut secara keseluruhan mencerminkan bahwa tata kelola teknologi informasi di PT Nusantara Retail belum mencapai tingkat kematangan yang memadai untuk mendukung pertumbuhan bisnis yang berkelanjutan dan pengelolaan risiko TI yang efektif.

Menghadapi kondisi tersebut, diperlukan sebuah evaluasi menyeluruh dan terstruktur terhadap tata kelola teknologi informasi PT Nusantara Retail menggunakan framework yang diakui secara internasional. Audit ini menggunakan COBIT 2019 (Control Objectives for Information and Related Technologies) sebagai kerangka kerja utama evaluasi. COBIT 2019 dipilih karena menyediakan governance and management objectives yang komprehensif dan terstruktur, mencakup seluruh aspek tata kelola TI mulai dari level strategis hingga operasional, serta dapat disesuaikan dengan karakteristik dan skala organisasi. Dengan melaksanakan audit berbasis COBIT 2019, diharapkan perusahaan memperoleh gambaran yang jelas mengenai kondisi aktual tata kelola TI, mengidentifikasi area yang memerlukan perbaikan, serta menyusun langkah-langkah peningkatan yang terukur dan prioritas dalam rangka mendukung transformasi digital yang aman, andal, dan berkelanjutan

**TUJUAN AUDIT**

Audit tata kelola teknologi informasi pada PT Nusantara Retail dilaksanakan dengan tujuan sebagai berikut:

1. Mengevaluasi efektivitas penerapan tata kelola dan manajemen teknologi informasi di PT Nusantara Retail berdasarkan framework COBIT 2019, mencakup aspek governance, risk management, information security, service management, dan performance monitoring.
2. Menilai tingkat kematangan (capability level) proses TI pada setiap domain COBIT 2019 yang diaudit menggunakan skala 0 hingga 5 berdasarkan COBIT 2019 Capability Level Model.
3. Mengidentifikasi risiko-risiko teknologi informasi yang berpotensi mengganggu kelangsungan operasional bisnis retail dan layanan e-commerce, baik risiko yang bersifat teknis, operasional, maupun keamanan informasi.

4. Mengevaluasi efektivitas kebijakan dan implementasi keamanan informasi dalam melindungi aset data perusahaan, termasuk data pribadi pelanggan, dari ancaman akses tidak sah, kebocoran data, dan serangan siber.
5. Menilai kesiapan organisasi dalam menghadapi gangguan layanan TI melalui mekanisme business continuity management dan disaster recovery, termasuk ketersediaan BCP, DRP, dan prosedur pemulihan sistem.
6. Mengevaluasi efektivitas proses change management dalam mengelola perubahan sistem TI guna meminimalkan risiko gangguan layanan akibat pembaruan atau modifikasi sistem.
7. Menilai efektivitas sistem penanganan insiden dan permintaan layanan TI, termasuk ketersediaan platform ticketing, penetapan SLA, dan prosedur eskalasi insiden.
8. Mengidentifikasi gap antara kondisi existing process tata kelola TI dengan standar dan best practice yang ditetapkan dalam COBIT 2019, serta memetakan prioritas perbaikan berdasarkan tingkat risiko dan dampak bisnis.
9. Memberikan rekomendasi perbaikan yang spesifik, terukur, dan berbasis COBIT 2019 guna meningkatkan kualitas, efektivitas, dan kematangan tata kelola teknologi informasi PT Nusantara Retail secara berkelanjutan.

**RUANG LINGKUP AUDIT**

Ruang Audit difokuskan pada evaluasi tata kelola teknologi informasi PT Nusantara Retail yang mencakup operasional sistem informasi toko, platform e-commerce nusantaramart.id, infrastruktur jaringan, manajemen data pelanggan, dan layanan dukungan TI internal. Pemilihan domain COBIT 2019 dilakukan berdasarkan identifikasi risiko utama layanan TI, kebutuhan pengendalian operasional, serta pemetaan terhadap permasalahan yang teridentifikasi selama tahap perencanaan audit.

| Domain | Subdomain | Nama Proses | Fokus Audit |
|---|---|---|---|
| EDM | EDM03 | Ensure Risk Optimization | Evaluasi mekanisme governance risiko TI di level manajemen |
| APO | APO12 | Managed Risk | Proses identifikasi, analisis, dan mitigasi risiko TI |
| **Domain** | **Subdomain** | **Nama Proses** | **Fokus Audit** |

| | | | |
|---|---|---|---|
| APO | APO13 | Managed Security | Kebijakan dan implementasi keamanan informasi |
| BAI | BAI06 | Managed IT Changes | Prosedur pengelolaan perubahan dan update sistem |
| DSS | DSS02 | Managed Service Requests and Incidents | Penanganan insiden dan keluhan layanan TI |
| DSS | DSS04 | Managed Continuity | Kesiapan disaster recovery dan business continuity |
| DSS | DSS05 | Managed Security Services | Kontrol akses, proteksi endpoint, dan keamanan data |
| MEA | MEA01 | Managed Performance and Conformance | Monitoring KPI layanan TI dan pelaporan kinerja |

**BATASAN AUDIT**

Audit ini difokuskan pada aspek tata kelola teknologi informasi dan tidak mencakup audit keuangan, audit infrastruktur fisik secara mendalam, penetration testing, maupun analisis source code aplikasi. Evaluasi dilakukan berdasarkan pendekatan observasional, identifikasi risiko layanan digital, studi dokumentasi, dan analisis kesesuaian tata kelola TI berdasarkan framework COBIT 2019.

**AUDIT FINDINGS**

Temuan audit disusun berdasarkan hasil review dokumentasi, observasi operasional, dan wawancara dengan staf divisi TI serta manajemen PT Nusantara Retail. Setiap temuan disajikan berdasarkan kondisi aktual yang ditemukan dan akar penyebabnya, diorganisasikan sesuai domain COBIT 2019 yang relevan..

1. **Domain EDM03 (Ensure Risk Optimization)**

   Kondisi : Berdasarkan hasil wawancara dengan manajemen IT dan review dokumentasi internal, PT Nusantara Retail belum memiliki IT Risk Committee maupun mekanisme formal untuk governance risiko TI di level board/manajemen. Pengelolaan risiko TI dilakukan secara ad-hoc oleh staf IT tanpa panduan kebijakan risiko yang terdokumentasi. Tidak terdapat risk appetite statement, risk tolerance threshold, maupun periodic risk governance review yang terstruktur.

   Penyebab : Kondisi ini disebabkan oleh belum adanya kesadaran manajemen puncak terhadap pentingnya IT risk governance sebagai bagian dari enterprise governance. Perusahaan berfokus pada ekspansi bisnis tanpa diimbangi

penguatan struktur tata kelola TI. Selain itu, tidak ada role atau jabatan formal yang bertanggung jawab atas IT Risk Management di tingkat strategis.

**2. Domain APO12 (Managed Risk)**

Kondisi : Tidak tersedia risk register TI yang terdokumentasi dan diperbarui secara berkala. Penilaian risiko (risk assessment) hanya dilakukan secara informal ketika terjadi insiden nyata, bukan secara proaktif. Risiko pada layanan e-commerce seperti serangan DDoS saat flash sale, kegagalan sistem pembayaran, dan potensi kebocoran data pelanggan belum dipetakan dan dimitigasi secara terstruktur. Pada event flash sale 12.12, server e-commerce mengalami overload karena tidak dilakukan capacity planning dan risk assessment sebelumnya.

Penyebab : Ketiadaan proses risk management yang sistematis disebabkan oleh keterbatasan sumber daya divisi IT (8 staf) yang menangani seluruh operasional TI sehingga tidak tersedia waktu dan kapasitas untuk melakukan risk assessment rutin. Selain itu, belum terdapat metodologi risk management yang diadopsi sebagai standar organisasi.

**3. Domain APO13 (Managed Security)**

Kondisi : Kebijakan keamanan informasi (Information Security Policy) belum tersedia dalam bentuk dokumen formal yang disahkan oleh manajemen. Pengamanan sistem dilakukan berdasarkan inisiatif individual staf IT tanpa panduan standar yang konsisten. Ditemukan bahwa akun administrator sistem e-commerce masih menggunakan password statis tanpa rotasi berkala, dan tidak menerapkan multi-factor authentication (MFA). Data pribadi pelanggan yang tersimpan dalam database belum sepenuhnya terenkripsi.

Penyebab : Belum adanya Information Security Management System (ISMS) yang terstandarisasi menyebabkan pengelolaan keamanan informasi berjalan tanpa arah yang jelas. Perusahaan belum pernah melakukan security audit sebelumnya, sehingga celah keamanan pada sistem tidak teridentifikasi secara proaktif. Kurangnya awareness keamanan informasi di kalangan manajemen juga berkontribusi terhadap rendahnya prioritas investasi keamanan TI.

**4. Domain BAI06 (Managed IT Changes)**

Kondisi : Proses perubahan sistem (change management) belum memiliki prosedur formal. Pembaruan dan patch sistem dilakukan langsung pada environment produksi tanpa melalui tahap testing, impact assessment, maupun approval dari manajemen. Hal ini terbukti menyebabkan downtime selama 3 jam 20 menit pada platform e-commerce saat flash sale 12.12, yang mengakibatkan estimasi kerugian transaksi senilai Rp 420 juta. Tidak terdapat change advisory board (CAB), change log, maupun rollback procedure yang terdokumentasi.

Penyebab : Ketiadaan prosedur change management yang formal disebabkan oleh budaya kerja yang cenderung reaktif dan tidak terstruktur dalam divisi IT. Tekanan untuk melakukan pembaruan sistem dengan cepat tanpa proses review menyebabkan langkah-langkah mitigasi risiko perubahan terabaikan. Tidak ada kebijakan organisasi yang mewajibkan proses change control sebelum implementasi perubahan sistem.

**5. Domain DSS02 (Managed Service Requests and Incidents)**

Kondisi : Penanganan keluhan dan insiden layanan TI dilakukan melalui pesan WhatsApp kepada staf IT tanpa sistem pencatatan formal. Tidak tersedia ticketing system, sehingga insiden yang dilaporkan tidak terdokumentasi, tidak dikategorikan berdasarkan prioritas, dan tidak dapat dievaluasi tren maupun waktu resolusinya. Pada bulan November–Desember 2024, tercatat lebih dari 40 keluhan pelanggan terkait kegagalan transaksi dan error pada aplikasi, namun seluruhnya ditangani tanpa prosedur yang terstandarisasi.

Penyebab : Ketiadaan incident management process yang formal disebabkan oleh belum adanya adopsi platform ITSM (IT Service Management) di perusahaan. Tidak ada standar Service Level Agreement (SLA) yang ditetapkan untuk waktu respons dan resolusi insiden. Selain itu, perusahaan belum memiliki kategorisasi insiden maupun eskalasi prosedur yang jelas.

**6. Domain DSS04 (Managed Continuity)**

Kondisi : PT Nusantara Retail belum memiliki Business Continuity Plan (BCP) maupun Disaster Recovery Plan (DRP) yang terdokumentasi. Proses backup data dilakukan secara manual oleh staf IT tanpa jadwal yang konsisten dan tanpa mekanisme verifikasi keberhasilan backup. Tidak terdapat secondary site atau redundansi infrastruktur untuk mendukung high availability sistem. Pada insiden

downtime flash sale 12.12, proses pemulihan sistem memerlukan waktu lebih dari 3 jam karena tidak ada prosedur recovery yang terstandarisasi.

Penyebab : Ketiadaan BCP dan DRP disebabkan oleh kurangnya pemahaman manajemen terhadap pentingnya continuity planning sebagai bagian dari strategi bisnis. Keterbatasan anggaran TI juga menyebabkan perusahaan belum berinvestasi pada infrastruktur redundansi dan solusi backup otomatis yang memadai.

**7. Domain DSS05 (Managed Security Services)**

Kondisi : Pengendalian akses terhadap sistem informasi dan database pelanggan belum menerapkan prinsip least privilege. Beberapa akun karyawan yang telah resign masih aktif dalam sistem. Tidak terdapat endpoint protection yang terstandarisasi pada seluruh perangkat kerja karyawan. Log aktivitas sistem tidak dipantau secara rutin, sehingga potensi unauthorized access tidak dapat dideteksi secara dini.

Penyebab : Lemahnya pengendalian keamanan operasional disebabkan oleh tidak adanya prosedur offboarding IT yang formal ketika karyawan keluar, serta tidak tersedianya tools monitoring keamanan yang memadai. Manajemen akses dilakukan secara manual tanpa Identity and Access Management (IAM) system, sehingga rentan terhadap human error dan kelalaian administrasi.

**8. Domain MEA01 (Managed Performance And Conformance)**

Kondisi : Tidak terdapat Key Performance Indicator (KPI) yang ditetapkan secara formal untuk mengukur performa layanan TI. Laporan kinerja TI tidak diproduksi secara periodik, sehingga manajemen tidak memiliki gambaran yang akurat mengenai uptime sistem, waktu respons insiden, maupun kualitas layanan e-commerce secara keseluruhan. Monitoring performa server dan aplikasi hanya dilakukan ketika terjadi gangguan, bukan secara proaktif dan berkelanjutan.

Penyebab : Ketiadaan mekanisme performance monitoring disebabkan oleh belum ditetapkannya framework pengukuran kinerja TI di perusahaan. Tidak ada dashboard monitoring yang terintegrasi, SLA yang disepakati antara divisi IT dan unit bisnis, maupun mekanisme pelaporan kinerja TI kepada manajemen secara berkala.

## REKOMENDASI AUDIT

Rekomendasi berikut disusun berdasarkan temuan audit dan mengacu pada governance and management objectives COBIT 2019. Setiap rekomendasi dirancang untuk meningkatkan capability level masing-masing domain menuju target yang lebih optimal.

### 1. Domain EDM03 (Ensure Risk Optimization)

Temuan : Tidak ada struktur governance risiko TI di level manajemen. PT Nusantara Retail belum memiliki IT Risk Committee, risk appetite statement, maupun kebijakan pengelolaan risiko TI yang terdokumentasi dan disahkan secara formal.

Rekomendasi : Organisasi disarankan untuk membentuk IT Risk Committee yang melibatkan manajemen puncak sebagai forum pengambilan keputusan risiko TI, sesuai dengan COBIT 2019 EDM03.01 - Evaluate Risk Management. Selain itu, perlu disusun IT Risk Policy yang memuat risk appetite, risk tolerance, dan risk ownership yang disahkan oleh manajemen sebagai landasan formal pengelolaan risiko TI di seluruh lini organisasi. Untuk memastikan keberlanjutan dan efektivitas governance risiko, perusahaan juga disarankan melaksanakan periodic governance review minimal dua kali per tahun guna mengevaluasi kesesuaian dan efektivitas pengendalian risiko TI secara menyeluruh.

### 2. Domain APO12 (Managed Risk)

Temuan : Tidak tersedia risk register TI yang terdokumentasi. Penilaian risiko hanya dilakukan secara ad-hoc ketika insiden terjadi, tanpa proses identifikasi dan mitigasi risiko yang proaktif dan terstruktur.

Rekomendasi : Perusahaan disarankan untuk mengembangkan IT Risk Register yang mencatat seluruh risiko TI beserta likelihood, impact, dan strategi mitigasinya sesuai dengan COBIT 2019 APO12.02 - Analyse Risk. Risk register tersebut perlu diperbarui secara berkala melalui IT Risk Assessment yang dilaksanakan minimal satu kali per kuartal, dengan penekanan khusus sebelum pelaksanaan event promosi besar seperti flash sale guna mengantisipasi lonjakan beban sistem. Di samping itu, perusahaan disarankan mengimplementasikan capacity planning tool yang mampu memberikan proyeksi kebutuhan kapasitas

infrastruktur secara proaktif sehingga insiden overload server seperti yang terjadi pada flash sale 12.12 dapat dicegah di masa mendatang.

**3. Domain APO13 (Managed Security)**

Temuan : Kebijakan keamanan informasi formal belum tersedia. Akun administrator menggunakan password statis tanpa rotasi berkala, tidak menerapkan MFA, dan data pribadi pelanggan dalam database belum sepenuhnya terenkripsi.

Rekomendasi : Organisasi perlu segera menyusun dan mengesahkan Information Security Policy yang mencakup klasifikasi data, kebijakan akses, dan prosedur perlindungan data pribadi sebagai fondasi Information Security Management System (ISMS), sesuai dengan COBIT 2019 APO13.01 - Establish and Maintain an ISMS. Implementasi enkripsi data pelanggan menggunakan standar AES-256 pada seluruh data yang tersimpan dalam database sistem perlu dilakukan sesegera mungkin untuk memitigasi risiko kebocoran data. Selain itu, penerapan Multi-Factor Authentication (MFA) pada seluruh akun administrator serta pemberlakuan password rotation policy dengan interval maksimal 90 hari untuk akun privileged sangat direkomendasikan guna meningkatkan ketahanan sistem terhadap ancaman akses tidak sah.

**4. Domain BAI06 (Managed IT Changes)**

Temuan : Tidak ada prosedur change management formal. Pembaruan sistem dilakukan langsung pada environment produksi tanpa impact assessment, testing, maupun approval manajemen, yang terbukti menyebabkan downtime 3 jam 20 menit saat flash sale 12.12.

Rekomendasi : Perusahaan disarankan untuk mengimplementasikan Change Management Procedure yang mewajibkan seluruh perubahan sistem melalui proses RFC (Request for Change), impact assessment, dan pengujian pada staging environment sebelum deployment ke produksi, sesuai dengan COBIT 2019 BAI06.01 - Evaluate, Prioritise and Authorise Change Requests. Pembentukan Change Advisory Board (CAB) yang terdiri dari IT Lead dan perwakilan unit bisnis juga diperlukan sebagai mekanisme review dan persetujuan formal terhadap setiap perubahan sistem yang bersifat kritis. Selain itu, penetapan rollback procedure yang terdokumentasi untuk setiap perubahan

kritis wajib dilakukan guna memastikan pemulihan sistem yang cepat apabila terjadi kegagalan pada proses deployment.

**5. Domain DSS02 (Managed Service Requests and Incidents)**

Temuan : Penanganan insiden dilakukan melalui WhatsApp tanpa sistem pencatatan formal. Tidak ada ticketing system, kategorisasi prioritas insiden, maupun SLA yang ditetapkan, sehingga lebih dari 40 keluhan pelanggan pada periode November-Desember 2024 tidak tertangani secara terstruktur.

Rekomendasi : Organisasi disarankan untuk mengadopsi platform ITSM (IT Service Management) seperti Freshservice atau Jira Service Management sebagai sistem ticketing dan tracking insiden yang terpusat, sesuai dengan COBIT 2019 DSS02.02 - Record, Classify and Prioritise Requests and Incidents. Penetapan Service Level Agreement (SLA) untuk setiap kategori insiden juga perlu segera dilakukan, dengan target penanganan insiden Critical kurang dari 1 jam, High kurang dari 4 jam, dan Medium kurang dari 8 jam. Di samping itu, penyusunan prosedur eskalasi insiden yang jelas beserta penetapan incident owner per kategori diperlukan untuk memastikan setiap insiden ditangani oleh pihak yang tepat secara efektif dan tepat waktu.

**6. Domain DSS04 (Managed Continuity)**

Temuan : Tidak tersedia BCP maupun DRP yang terdokumentasi. Backup data dilakukan secara manual tanpa jadwal konsisten dan tanpa verifikasi integritas, sehingga proses pemulihan saat insiden berlangsung lebih dari 3 jam tanpa panduan yang jelas.

Rekomendasi : Perusahaan disarankan untuk segera menyusun Business Continuity Plan (BCP) dan Disaster Recovery Plan (DRP) yang mencakup scenario analysis, penetapan Recovery Time Objective (RTO), dan Recovery Point Objective (RPO) yang terukur, sesuai dengan COBIT 2019 DSS04.02 - Maintain a Continuity Strategy. Implementasi automated backup solution dengan jadwal backup harian untuk data transaksional dan mingguan untuk data master juga perlu dilakukan, disertai mekanisme verifikasi integritas backup secara otomatis untuk memastikan keandalan data cadangan. Untuk memvalidasi kesiapan organisasi dalam menghadapi situasi darurat, pelaksanaan

disaster recovery simulation (DRS) minimal satu kali per tahun sangat direkomendasikan sebagai bagian dari siklus pengujian dan pemeliharaan DRP.

**7. Domain DSS05 (Managed Security Services)**

Temuan : Pengendalian akses belum menerapkan prinsip least privilege. Beberapa akun karyawan yang telah resign masih aktif dalam sistem, tidak ada IAM system, dan endpoint protection belum terstandarisasi di seluruh perangkat kerja.

Rekomendasi : Organisasi perlu mengimplementasikan Identity and Access Management (IAM) system dengan penerapan prinsip least privilege dan role-based access control (RBAC) untuk memastikan setiap pengguna hanya memiliki akses yang sesuai dengan tanggung jawabnya, sesuai dengan COBIT 2019 DSS05.04 - Manage User Identity and Logical Access. Penetapan IT offboarding checklist yang mewajibkan deaktivasi seluruh akun sistem paling lambat 1x24 jam setelah karyawan keluar dari perusahaan juga perlu segera diberlakukan guna menutup potensi celah akses tidak sah. Selain itu, standardisasi endpoint protection yang mencakup antivirus, anti-malware, dan firewall pada seluruh perangkat kerja karyawan, serta pengaktifan system activity log monitoring dengan alert otomatis untuk aktivitas anomali, diperlukan untuk meningkatkan efektivitas pengendalian keamanan operasional secara menyeluruh.

**8. Domain MEA01 (Managed Performance And Conformance)**

Temuan : Tidak ada KPI TI yang ditetapkan secara formal dan monitoring layanan hanya dilakukan secara reaktif ketika terjadi gangguan. Manajemen tidak memiliki laporan kinerja TI yang dapat digunakan sebagai dasar pengambilan keputusan.

Rekomendasi : Perusahaan disarankan untuk menetapkan IT KPI dashboard yang mencakup metrik uptime sistem dengan target minimal 99,5%, rata-rata waktu resolusi insiden, jumlah insiden per bulan, dan performa transaksi e-commerce, sesuai dengan COBIT 2019 MEA01.03 - Collect and Process Performance and Conformance Data. Implementasi tools monitoring proaktif seperti Grafana, Zabbix, atau New Relic juga sangat direkomendasikan untuk memungkinkan pemantauan performa server dan aplikasi secara real-time dan

berkelanjutan, sehingga potensi gangguan dapat dideteksi dan ditangani sebelum berdampak pada pengguna. Untuk mendukung proses pengambilan keputusan manajemen, produksi IT Performance Report bulanan yang memuat analisis kinerja layanan TI secara komprehensif perlu dijadikan kewajiban rutin divisi TI.

## KESIMPULAN

Berdasarkan hasil evaluasi terhadap delapan domain COBIT 2019, secara keseluruhan tata kelola teknologi informasi PT Nusantara Retail masih menunjukkan kesenjangan yang cukup signifikan terhadap standar best practice yang ditetapkan. Dari delapan domain yang diaudit, enam domain berada pada Capability Level 1 (Performed), yaitu EDM03, APO12, APO13, BAI06, DSS04, dan MEA01, sementara dua domain yaitu DSS02 dan DSS05 berada pada Capability Level 2 (Managed). Kondisi ini mencerminkan bahwa sebagian besar proses TI di perusahaan telah berjalan secara operasional, namun belum dikelola secara terencana, terdokumentasi, dan terstandarisasi sesuai dengan prinsip good IT governance.

Pada domain EDM03, ketiadaan struktur IT Risk Governance di level manajemen menunjukkan bahwa perusahaan belum memenuhi governance objective COBIT 2019 yang mensyaratkan adanya mekanisme evaluasi, pengarahan, dan pemantauan risiko TI secara formal. Domain APO12 dan APO13 yang berada pada Level 1 mencerminkan bahwa pengelolaan risiko TI dan keamanan informasi masih bersifat ad-hoc dan bergantung pada inisiatif individual, tanpa didukung oleh kebijakan, prosedur, maupun instrumen pengelolaan yang terstandarisasi. Kondisi ini tidak selaras dengan management objectives COBIT 2019 yang mensyaratkan adanya risk register, risk assessment berkala, Information Security Policy, serta ISMS yang terdokumentasi.

Domain BAI06 yang berada pada Level 1 merupakan salah satu temuan paling kritis dalam audit ini, mengingat ketiadaan prosedur change management telah terbukti menyebabkan insiden downtime yang berdampak langsung terhadap kerugian bisnis. COBIT 2019 mensyaratkan bahwa seluruh perubahan sistem harus

melalui proses evaluasi, otorisasi, dan pengujian yang terstruktur sebelum diimplementasikan pada environment produksi. Domain DSS04 yang berada pada Level 1 juga mencerminkan ketidaksesuaian yang mendasar, karena tidak tersedianya BCP dan DRP berarti perusahaan belum memenuhi persyaratan COBIT 2019 dalam hal kesiapan menghadapi gangguan layanan yang bersifat kritis.

Domain DSS02 dan DSS05 yang berada pada Level 2 menunjukkan bahwa penanganan insiden dan pengelolaan keamanan layanan operasional telah berjalan dengan derajat perencanaan yang lebih baik dibandingkan domain lainnya, meskipun masih memerlukan peningkatan dari sisi standardisasi, dokumentasi, dan pengukuran kinerja. Domain MEA01 yang berada pada Level 1 mencerminkan absennya mekanisme monitoring dan pelaporan kinerja TI yang terstruktur, sehingga manajemen tidak memiliki visibilitas yang memadai terhadap kualitas dan efektivitas layanan TI yang sedang berjalan.

Di sisi lain, PT Nusantara Retail telah menunjukkan komitmen operasional dalam menjalankan layanan TI yang mendukung bisnis retail dan e-commerce. Ketersediaan infrastruktur TI, kemampuan divisi IT dalam menangani kebutuhan operasional sehari-hari, serta adanya kesadaran awal terhadap pentingnya keamanan sistem mencerminkan bahwa fondasi teknis untuk peningkatan tata kelola TI telah tersedia. Yang diperlukan adalah penguatan pada dimensi governance, kebijakan, prosedur, dan mekanisme pengukuran kinerja.

Dengan mengimplementasikan seluruh rekomendasi yang disusun dalam laporan ini secara konsisten dan terencana, PT Nusantara Retail diproyeksikan dapat mencapai Capability Level 3 (Established) pada seluruh domain dalam kurun waktu 12 hingga 18 bulan ke depan. Pencapaian Level 3 pada seluruh domain akan menempatkan perusahaan pada posisi yang jauh lebih baik dalam mengelola risiko TI, menjaga keamanan dan integritas data pelanggan, menjamin ketersediaan layanan digital, serta mendukung pertumbuhan bisnis e-commerce secara berkelanjutan yang selaras dengan prinsip good IT governance COBIT 2019.